



HACKTHEBOX

Bug Bounty Program

CBBH Exam Report

Report of Findings

HTB Certified Bug Bounty Hunter (CBBH) Exam Report

Candidate Name: Nguyễn Đức Cảnh

Tên công ty /Khách Ltd.

Version: 1.0

Table of Contents

1	Statement of Confidentiality	3
2	Engagement Contacts	4
3	Executive Summary	5
3.1	Approach	5
3.2	Scope	6
3.3	Assessment Overview and Recommendations	6
4	Web Application Assessment Summary	7
4.1	Summary of Findings	7
5	Technical Findings Details	8
	SQL inject	8
	Weak password credential	9
A	Appendix	10
A.1	Flags Discovered	10

1 Statement of Confidentiality

The contents of this document have been developed by Hack The Box. Hack The Box considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Hack The Box. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Hack The Box.

The contents of this document do not constitute legal advice. Hack The Box's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Hack The Box external or internal infrastructure.

2 Engagement Contacts

Viết tắt của công ty đó Contacts		
Contact	Title	Contact Email
TODO Name	TODO Title	TODO Email

Assessor Contact		
Assessor Name	Title	Assessor Contact Email
Nguyễn Đức Cảnh	Hunter Canh	0206canh@gmail.com

3 Executive Summary

Tên công ty /Khách Ltd. (“Viết tắt của công ty đó” herein) invited Nguyễn Đức Cảnh to a private bug bounty program to perform a targeted Web Application Penetration Test of Viết tắt của công ty đó’s externally facing web applications to identify high-risk security weaknesses, determine the impact to Viết tắt của công ty đó, document all findings in a clear and repeatable manner, and provide remediation recommendations. The following types of findings were in-scope for this private bug bounty program:

- Sensitive or personally identifiable information disclosure
- Cross-Site Scripting (XSS)
- Server-side or remote code execution (RCE)
- Arbitrary file upload
- Authentication or authorization flaws, such as insecure direct object references (IDOR), and authentication bypasses
- All forms of injection vulnerabilities
- Directory traversal
- Local file read
- Significant security misconfigurations and business logic flaws
- Exposed credentials that could be leveraged to gain further access

The following types of activities were considered out-of-scope for this bug bounty program:

- Scanning and assessing any other IP in the Entry Point’s network
- Physical attacks against Viết tắt của công ty đó properties
- Unverified scanner output
- Man-in-the-Middle attacks
- Any vulnerabilities identified through DDoS or spam attacks
- Self-XSS
- Login/logout CSRF
- Issues with SSL certificates, open ports, TLS versions, or missing HTTP response headers
- Vulnerabilities in third party libraries unless they can be leveraged to significantly impact the target
- Any theoretical attacks or attacks that require significant user interaction or low risk

Nguyễn Đức Cảnh performed testing under a “Black Box” approach from , to without credentials or any advance knowledge of Viết tắt của công ty đó’s web applications with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Nguyễn Đức Cảnh sought to demonstrate the full impact of every vulnerability, up to and including internal network access.

3.1 Approach

3.2 Scope

The scope of this assessment was as follows TODO *.trilocor.local and any and all open web server ports discovered on the target IP address provided at the start of the assessment.

In Scope Assets

Host/URL/IP Address	Description
TODO www.triclor.local	Main Trilocor website/unauthenticated
TODO exam IP address	PR website/unauthenticated
TODO exam IP address	Jobs Portal/unauthenticated
TODO exam IP address	HR website/unauthenticated
TODO exam IP address	Trilocor online store/unauthenticated

3.3 Assessment Overview and Recommendations

During the course of testing against Nguyễn Đức Cảnh identified ...

TODO SUMMARY OF FINDINGS AND RECOMMENDATIONS HERE

4 Web Application Assessment Summary

Nguyễn Đức Cảnh began all testing activities from the perspective of an unauthenticated user on the internet. Viết tắt của công ty đó provided the tester with a single URL and IP address but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, Nguyễn Đức Cảnh uncovered a total of 2 findings that pose a material risk to Viết tắt của công ty đó's information systems. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **1 Critical** and **1 High** vulnerabilities were identified:

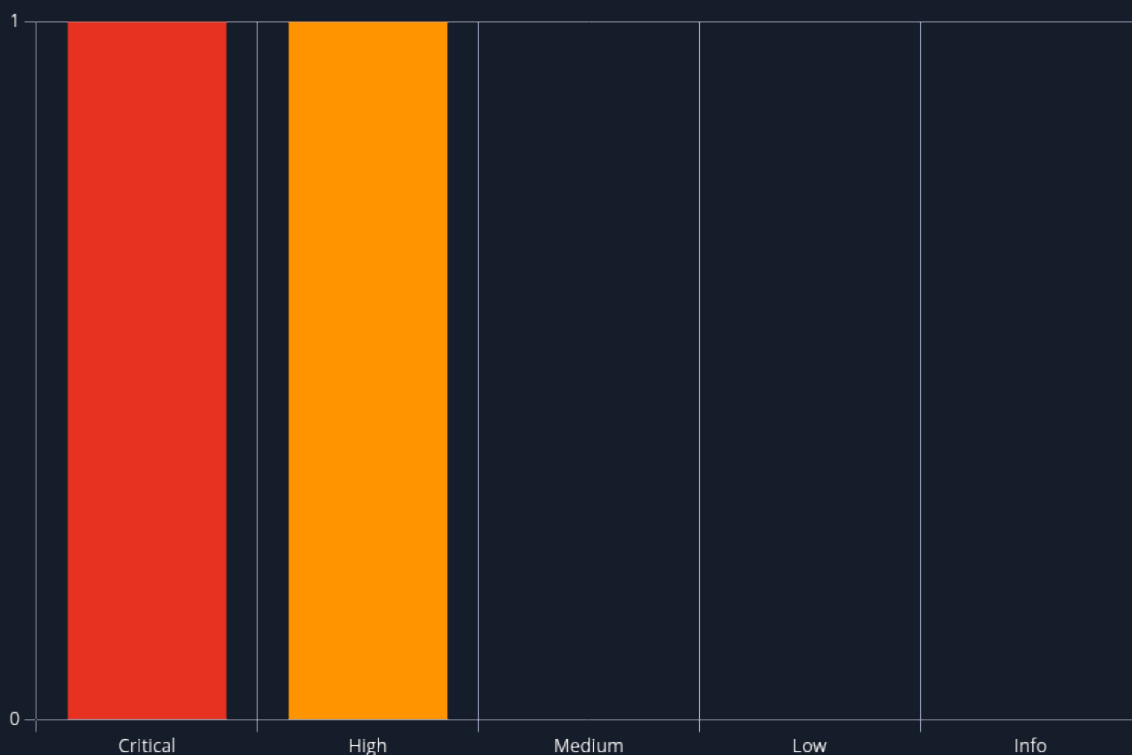


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	9.9 (Critical)	SQL inject	8
2	7.2 (High)	Weak password credential	9

5 Technical Findings Details

1. SQL inject - Critical

CWE	CWE-564 - SQL Injection: Hibernate
CVSS 3.1	9.9 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:L
Root Cause	TODO DESCRIPTION
Impact	TODO IMPACT
Remediation	TODO REMEDIATION
References	-

Finding Evidence

ADD COMMAND OUTPUT AS APPROPRIATE

TODO ADD SCREENSHOTS AS APPROPRIATE

ADVICE:

- Fix logic code

2. Weak password credential - High

CWE	CWE-521 - Weak Password Requirements
CVSS 3.1	7.2 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:L/I:L/A:N
Root Cause	TODO DESCRIPTION
Impact	TODO IMPACT
Remediation	TODO REMEDIATION
References	-

Finding Evidence

ADD COMMAND OUTPUT AS APPROPRIATE

TODO ADD SCREENSHOTS AS APPROPRIATE

ADVICE:

- Update strong pass and policy

A Appendix

A.1 Flags Discovered

Flag #	Application	Flag Value	Flag Location	Method Used
1.	TODO HOSTNAME	TODO HTB RANDOM VALUE	TODO Web root	TODO Command Injection (example)
2.				
3.				
4.				
5.				
6.				
7.				
8.				
9.				
10.				

End of Report

*This report was rendered
by SysReptor with
♥*